

CHAPTER 1

INTRODUCTION

1.1 Introduction

The rapid adoption of digital technologies has transformed the entire process of collecting and storing information in the clinic. Transitioning from paper processes to the use of EHRs in clinics and hospitals which made healthcare information management infrastructure crucial since sensitive patient data must be protected. Information security and protection of secret patient information has always been an area of concern, especially in cases of breaches where patient privacy and security is put at risk.

While the importance of adopting a secure infrastructure becomes obvious with the growth in the number of cybersecurity threats, there are still many small clinics and hospitals which rely on the legacy on-premises server solution and ignore the growing risks linked with the lack of enough cybersecurity measures. The traditional server infrastructure does not allow implementing any additional measures to prevent attacks or limit their impact on the system, thus increasing the risks Significantly. This project aims at designing and implementing a cloud-based solution that would be able to effectively protect patients' confidential information from malicious attacks and unauthorized access. The proposed cloud-based system will feature a three-tier architecture and be deployed into isolated network subnets using Virtual Private Cloud (VPC) and Infrastructure as Code (IaC) solutions such as Terraform. The DevSecOps pipeline will enable developers to scan every piece of code before deployment.

A practical example of the need for this system is seen at the case of the Alamin Clinic which suffered a cyberattack and became a victim of ransomware. Thus, the selected organization will provide requirements for the system design and implementation to solve the identified problem.

1.2 Problem Statement

At present, the management of the patient data management system at the Alamin Clinic relies on an on-premises physical server that provides services of the web frontend, application backend, and patient database in a single network without any segmentation of layers of the architecture. In other words, all of these elements of infrastructure are manually configured, deployed, and managed; for example, the code for applications is deployed to a production environment through FTP or USB drive while updates for antivirus programs and firewalls are applied on a manual basis with significant delays.

However, such an approach revealed its flaws when the clinic was hacked and its patients' data was affected by the ransomware threat. The hackers gained access to the system, Found its way into the network and encrypted the entire database. Due to the lack of network segmentation and isolation, all the components of the system became vulnerable and unusable until the data is restored manually. The lack of automation and regular backups increased downtime and made it impossible to restore data at time.

It appears that the problem described above align with a wider problem that affects small healthcare organizations. Argaw *et al.* (2019) noted that cyberattacks in hospitals take advantage of old infrastructure, poor network segregation, and inadequate patching policies. Moreover, as Al-Issa *et al.* (2019) reported, cloud computing technologies used in the healthcare industry have some specific problems related to access management and Unprotected date, among others.

In summary, the problems described above reveal one major gap typical for small scale organizations that is a lack of proper information security measures implemented since the beginning. To address the issue, the proposed solution will be based on cloud computing and ensure security from the very beginning through Compliance with the security-by-design principle.

1.3 Project Aim

The aim of this project is to design and deploy a secure cloud-based Patient Data Management System for Alamin Clinic using a three-tier architecture on AWS, Integrating Infrastructure as Code and a DevSecOps pipeline to ensure automated, reproducible, and security-validated deployments.

1.4 Project Objectives

The objectives of the project are:

(a) To investigate core concepts including cloud computing security, three-tier architecture, network segmentation, Identity and Access Management, and secure system design practices within the context of healthcare applications.

(b) To develop a secure Cloud-Based Patient Data Management System based on a three-tier architecture on AWS, covering Virtual Private Cloud networking, access control through IAM and Role-Based Access Control (RBAC), and a DevSecOps CI/CD pipeline with integrated security scanning.

(c) To evaluate the performance of the system using automated vulnerability assessment tools such as Trivy, SonarQube, and Checkov. The performance evaluation includes RTO testing via a ransomware recovery simulation test and a HIPPA compliance test using AWS Security Hub. Lastly, User Acceptance Testing (UAT) will be carried out using Doctors, Admins, and Patients.

1.5 Project Scope

This system addresses the development of a secure patient data management system that is designed to serve doctors, administration staff, and patients of the Alamin clinic. This system will be developed as a functional prototype on AWS, and security monitoring will be done using the results of vulnerability scans, CloudWatch, and recovery time tests.

1.5.1 In-Scope

The project will be run within the following scopes:

- (a) Core patient record management functionality, including Patient Registration, Medical Records Management, Appointment Scheduling, and User Authentication with Role Management (Doctor, Admin, Patient).
- (b) Design of an AWS Virtual Private Cloud (VPC) with public subnets and private subnets for each respective layer
- (c) A 3 tier architecture that includes a React frontend layer hosted in S3, a Node.js/Express backend layer on EC2 instance, and a PostgreSQL database layer on Amazon RDS.
- (d) AWS services include but not limited to VPC, EC2, RDS, App Load Balancer (ALB), NAT Gateway, and Internet Gateway.
- (e) Security and Network Groups Access Control Lists (NACLs).
- (f) Identity and Access Management (IAM) with least-privilege policies and Role-Based Access Control (RBAC) applied across all three user roles.
- (g) Data encryption at rest using AES-256 through AWS Key Management Service (KMS) and encryption in transit using TLS/HTTPS.
- (h) A DevSecOps CI/CD pipeline built on GitHub Actions with Docker containerization and Terraform IaC, incorporating automated security scanning using Trivy (container images), SonarQube (static code analysis), and Checkov (IaC misconfiguration scanning).
- (i) Monitoring and audit logging using Amazon CloudWatch and AWS CloudTrail.
- (j) HIPAA compliance posture assessment using AWS Security Hub.

1.5.2 Data and Subjects

The system will be evaluated using a pilot dataset of simulated patient records generated for testing purposes. User Acceptance Testing will be conducted with a minimum of three representative participants, one per user role (Doctor, Admin, Patient). No real patient data will be used during development or testing.

1.5.3 Out-of-Scope

To maintain focus on the security architecture and infrastructure, the following modules are explicitly excluded from this project:

(i) hospital billing and insurance claim management; (ii) pharmacy inventory and dispensing management; (iii) Emergency Room (ER) management; and (iv) specialized Obstetrics and Gynaecology (O&G) clinical modules.

1.6 Project Importance

The importance of the project comes out in several aspects: clinical, technical, and academic.

First of all, when it comes to clinical issues, one should understand that patient information is considered to be one of the most sensitive types of personal data. An information leak or loss of availability caused by a ransomware attack like in Alamin Clinic's case may have serious consequences, both for patients and doctors, as well as reputational and legal ramifications. Therefore, the development of a system that will be characterized by high availability, security, and integrity of patient data cannot be regarded as a technical task.

Secondly, one needs to consider the technical part of the project. Infrastructure as Code and DevSecOps approaches allowed for the conversion of an outdated and manual environment into a self healing infrastructure with the use of code and security validation. The whole infrastructure is coded using the Terraform language, and this gives us the opportunity to redeploy it from a clean state in minutes. Furthermore, a security scan conducted prior to deployment ensures that any threats are discovered and prevented from moving forward.

Finally, On the academic aspect. In this case, the project allows for practical application of the theoretical notions in terms of cloud security. Using HIPAA as the standard of compliance and AWS Security Hub as an evaluation tool.

1.7 Report Organization

This report is organized as follows:

Chapter 1: Introduction presents the background to the project, the problem statement at Alamin Clinic, the project aim and objectives, scope, and the importance of the study.

Chapter 2: Literature Review presents the complete literature analysis relevant to the system. technologies, frameworks, security practices, encryption mechanisms, Infrastructure as Code, and DevSecOps practices. This chapter discusses the strengths and weaknesses of existing systems and identifies the research gaps that the proposed solution attempts to fill.

Chapter 3 discusses the technique employed throughout the project. It explains the development methodology, tools, techniques, and the overall project workflow that guides the design and execution of the PDMS.

Chapter 4 is about the system requirements and the proposed solution design. This includes functional and non-functional specifications, followed by system design architecture, database schema, security policies and system design interface.

Chapter 5: Conclusion summarizes the achievement of the project objectives, reflects on the limitations of the current implementation, and proposes directions for future improvement.